Theoretical Learnings:

1. Threat hunting Methodologies:

- Threat hunting is the art of finding what your automated alerts missed. It assumes that the breach has already occurred and looks for subtle footprints.
- While threat hunting you don't just look at logs, you start with questioning. Let's say if an attacker used compromise attack used compromised credentials (T1078), will I see logins from unusual geolocation at 2:00 AM?
- The TaHiTi Framework: This framework is an popular model for structured hunting. It follows a life cycle: Prepare (target) > Execute (Hunting) > Act (Report).
- Data Strategy: To hunt effectively, you need low signal, high value data. Standard firewall logs aren't enough; you need EDR Telemetry like Process trees, registry changes and DNS Logs to find DGA or tunnelling.

2. Advances SOAR Automation:

- SOAR (Security Orchestration, Automation, and Response) is the glue that connects your tools.
- Automation is a single task (for example: Lookup this IP in VirusTotal).
- Orchestration is the workflow that connects multiple tools (for example: If VirusTotal says the IP is malicious, block it in the Firewall and disable the User in AD).
- The Playbook Logic: A good playbook should follow a "Standard Operating Procedure" (SOP).
  Extract URL -> Sandbox analysis -> If malicious, search entire O365 tenant for the same email -> Purge all instances.
- Advanced SOAR isn't 100% autonomous. It uses "Approval Nodes" where a human clicks "Yes" before a disruptive action (like isolating a CEO's laptop) occurs.

3. Post-Incident Analysis & Continuous Improvement:

- Root cause analysis: The 5 Whys: A simple technique where you ask "Why?" until you hit the process failure.

  Why was the server breached? It had a vuln. Why? It wasn't patched. Why? It wasn't in the asset inventory. (The root cause isn't the vuln; it's the inventory process).
- The output of a Post-Incident Review should result in new detection rules (SIEM), new playbooks (SOAR), or policy changes.
- MTTD (Mean Time to Detect): Measures visibility.
- MTTR (Mean Time to Repond): Measures efficiency/automation.

4. Adversary Emulation Techniques:

- This is a library of simple tests mapped to MITRE ATT&CK. You run a small command (e.g., a PowerShell script that mimics credential dumping) to see if your SIEM actually fires an alert.

- The Red Team (Attacker) performs an action, and the Blue Team (SOC) watches the logs in real-time to see how it looks.
- Tools like **MITRE Caldera** or **Scythe** automate these attacks so you can test your defence's daily, not just once a year.

5. Security Metrics and Executive Reporting:

- The most critical metric is when how many days the attack was in the network before we caught them? Reducing the dwell time reduces the cost of the breach.
- Avoiding technical jargon; use a stoplight system (Red, Amber, Green)

  Bad: we have 400 unpatched CVEs.

  Good: 70% of our critical assets are protected against the top 10 exploited vulnerabilities, a 15% improvement from last month.

- If false positive is too high, your analysts are exhausting out, high FP rates are a signal that you need to tune your detection logic or use better Threat intel.